CO1 – ASSIGNMENT 1

Design and Develop a Complete Ethical-Hacking Engagement Framework

For a University's Authorized Security-Assessment Programme

Course details	**Student details**
Course Code: ITA1439 Course Name: Ethical Hacking Slot: A	Student Name: SHAIK ARSHAD Register Number: 192425080 Department: AIML

Submitted as an individual assignment

Executive Summary

This assignment proposes a controlled, repeatable and scalable governance framework for the university's security-assessment programme. It covers approximately 20 initial systems and 50 staff, with a design that can expand to the whole university and include external assessors. The framework joins written authorization, asset and scope control, legal review, threat modelling, ethical conduct, isolated-lab testing, evidence handling, coordinated vulnerability disclosure and programme evaluation.

The central rule is simple: a security test is permitted only when the university has authority over the target, the target is explicitly listed in an approved scope, the test window and methods are agreed, and the tester has accepted the rules of engagement. A technical opportunity or a verbal request is never a substitute for written permission.

The framework is a design-level proposal. No live exploitation is conducted. The lab example uses a host-only virtual network and documentation/verification operations only.

Programme Context and Assumptions

- Initial environment: student portal, learning-management system (LMS), university email service and campus network; approximately 20 systems and 50 staff.
- Stakeholders: university management, IT/security team, system owners, data-protection/privacy representative, legal office, internal testers, external assessors and affected service teams.
- Testing may involve systems containing personal data. Production data must not be copied into the lab; synthetic or masked data is preferred.
- The university owns or has documented authority to test each listed asset. Third-party hosted services require written permission from the provider as well as the university.
- All examples, counts, timelines and evaluation measurements below are proposed planning values, not measured results from a live university programme.

TASK 1 – Enquiry and Framework Blueprint

1.1 Governance requirements

Requirement ID	Requirement	Governance response
R1	Identify and maintain an authoritative inventory of systems, owners and hosting arrangements.	Asset register with unique asset IDs and owner approval.
R2	No engagement begins without documented authority.	Signed authorization record with dates, approver and permitted testers.
R3	Define exact targets, exclusions, methods and test windows.	Engagement-specific Scope and Rules of Engagement (RoE).
R4	Protect personal, confidential and operational data.	Data minimisation, masking, access controls, retention and secure deletion.
R5	Ensure legal and contractual obligations are checked before testing.	Legal/privacy review and third-party written consent where required.
R6	Model realistic threats without exceeding approved test boundaries.	Threat model informs safe test scenarios and priorities.
R7	Use a contained environment for hands-on exercises.	Kali Linux and authorized target VMs on host-only network.
R8	Report, triage and remediate findings consistently.	Structured finding report, severity, owner, due date and retest status.
R9	Support internal and external assessors and programme growth.	Role-based access, assessor onboarding, standard templates and audit logs.

1.2 Framework blueprint

Stage	Input	Control / activity	Output and hand-off
1. Request	Department request and business	Register request; identify asset owner	Engagement ID and initial request.

	reason	and impact.	
2. Authorization	Request, asset inventory, proposed testers	Management/system owner approval; legal/privacy and vendor consent checks.	Signed authorization record.
3. Scope & RoE	Approved assets and objectives	Set targets, exclusions, methods, time window, stop conditions and contacts.	Version-controlled RoE.
4. Threat & ethics	System context and likely attackers	Classify threats; approve ethical conduct and safe scenarios.	Threat model and test plan.
5. Lab / test	Approved test plan	Validate tools and methods in isolated lab; production tests only if separately authorized.	Test logs and evidence.
6. Findings	Evidence and impact assessment	Validate, redact sensitive data, assign severity and owner.	Structured finding report.
7. Disclosure	Validated finding and remediation plan	Coordinate with owner; track deadlines and escalation.	Disclosure log and remediation status.
8. Closure	Retest and approvals	Confirm fixes, remove access, securely dispose of data and review lessons.	Closure report and updated risk register.

1.3 Enquiry questions

1. Who has authority to approve an assessment, and how is that authority recorded?
2. Which systems, accounts, networks, dates and techniques are included or excluded?
3. Which Indian laws, data-protection duties and third-party contracts apply to the target?
4. How are attacker types and likely threats translated into safe test scenarios?
5. How are findings validated, prioritised, disclosed and tracked until remediation?
6. How can the programme scale without losing accountability or auditability?

1.4 Acceptance criteria

Criterion	Acceptance test
Authorization	Every engagement has a signed, dated approval before any test activity.
Scope clarity	Every target has an asset ID; exclusions and stop conditions are explicit.
Legal/privacy	Legal and privacy checks are recorded, including vendor permission where applicable.
Safety	No prohibited activity; lab traffic is contained and production testing has change controls.
Traceability	Requests, approvals, evidence, findings, decisions and closure are logged.
Disclosure	Each validated finding has an owner, severity, due date and escalation path.
Scalability	Templates and roles work for both a department pilot and university-wide assessments.

Rationale: these criteria turn broad security goals into verifiable controls. They prevent a technically successful test from being treated as acceptable if it lacked authority, exceeded scope or mishandled data.

TASK 2 – Hacker Threat Model and Classification

2.1 Classification criteria

Classify an actor using evidence of authorization, intent, behaviour, capability and impact. Authorization is the first discriminator: a person is not a white-hat merely because they claim a helpful purpose. Record the primary label and any secondary behaviour where categories overlap.

Actor type	Motivation	Typical capability	Likely university targets
White-hat	Improve security with permission.	Professional assessment, controlled tools, documented methods.	Portal, LMS, email, network; only approved scope.
Black-hat	Financial gain, theft, disruption or espionage.	Credential theft, malware, exploitation, persistence.	Student records, staff accounts, research data, payment systems.
Grey-hat	Curiosity or recognition; may act without permission.	Moderate technical skills; probes or discloses without approval.	Public portal, exposed services, misconfigured storage.

Script kiddie	Experimentation, attention or disruption.	Uses downloaded tools with limited understanding.	Wi-Fi, login pages, public-facing services.
Hacktivist	Political/social cause, publicity or protest.	Defacement, leaks, denial-of-service, coordinated campaigns.	University website, public communications, email.
Insider	Grievance, profit, coercion or accidental misuse.	Legitimate access combined with knowledge of internal systems.	HR/student databases, shared drives, admin consoles.
State-sponsored	Strategic intelligence, influence or disruption.	Well-resourced, persistent, targeted operations.	Research, intellectual property, privileged accounts, infrastructure.

2.2 Consistent classification procedure

7. Establish whether explicit written authorization exists for the specific asset, activity and time.
8. Determine the actor's apparent intent from observable behaviour; do not infer intent from identity alone.
9. Assess capability from demonstrated actions, tools, access and operational sophistication.
10. Record the actual target and impact, including confidentiality, integrity and availability effects.
11. Assign a primary category and record uncertainty or secondary labels in the case notes.

2.3 Borderline actor analysis

Example: a student discovers an exposed university login page, runs an automated scanner without permission, finds a weakness and emails the IT team without accessing records.

Possible classification	Reason supporting it	Limitation
Grey-hat	The student tested without explicit authorization but may intend to help.	Good intent does not make the activity authorized or lawful.
Script kiddie	If the scanner was downloaded and used without understanding its operation, this label describes capability.	It describes skill level, not the ethical or legal status.
Final classification	Primary: grey-hat; secondary descriptor: low-skill/tool-dependent.	The decisive fact is unauthorized testing; the tool-use detail is a capability descriptor.

The final label is grey-hat because the actor acted outside written permission. The script-kiddie description may be added if evidence confirms limited understanding. The university should preserve the report, tell the student to stop further testing and route the issue through the responsible-disclosure contact.

TASK 3 – Ethics and Code-of-Conduct Module

3.1 Core principles

- Written authorization: do not begin until the approval is signed and verifiable.
- Scope discipline: test only named assets, accounts, methods and time windows.
- Do no harm: avoid unnecessary service disruption, data modification, persistence or destructive payloads.
- Confidentiality: access the minimum data needed; do not copy, publish or disclose personal information.
- Integrity: preserve evidence accurately; do not alter logs or conceal actions.
- Transparency: keep timestamped activity logs and promptly report unexpected outcomes.
- Competence and accountability: use approved tools, follow change controls and accept responsibility for actions.
- Responsible reporting: disclose findings only through approved channels and support remediation.

3.2 Decision checks

Check	Question	If NO
Authority	Is a signed authorization current and applicable?	Stop; obtain approval.
Target	Is the target explicitly listed in the RoE?	Do not interact; request scope change.
Method	Is the proposed technique permitted?	Do not run it; seek written amendment.
Data	Can the objective be met with synthetic or minimal data?	Pause and consult privacy lead.

Safety	Is the activity within the approved window and risk limit?	Stop and reschedule or redesign.
Disclosure	Is the reporting recipient approved?	Use the designated security contact.

3.3 Scenario test cases

Scenario	Classification	Code response
Tester performs a low-impact scan on an approved staging host during the agreed window.	Acceptable	Log the scan, preserve evidence and continue within RoE.
Tester notices a neighbouring vendor IP responding and considers scanning it.	Borderline / prohibited until approved	Do not scan; record observation and obtain vendor authorization and scope amendment.
Tester downloads a student database to prove a read-access issue.	Unacceptable	Stop, secure evidence without retaining the dataset, notify incident lead and privacy/legal contacts.
Tester finds a critical flaw outside the approved time window.	Unacceptable to continue testing	Stop active testing; notify the engagement lead and request an emergency authorization or safe handover.
Tester reports a validated issue through the university's private disclosure channel.	Acceptable	Acknowledge, assign owner and track remediation.

This module preserves trust because the same rules apply to employees and contractors. A tester's technical skill never overrides authorization, confidentiality or the duty to avoid harm.

TASK 4 – Legal-Compliance Mapping

The university is based in India, so Indian law is the primary legal baseline. The US Computer Fraud and Abuse Act (CFAA), 18 U.S.C. §1030, is included as an international comparison, not as a substitute for Indian law. It may become relevant where a US computer or jurisdictional connection is involved; counsel must assess jurisdiction.

4.1 Offences, obligations and controls

Law / provision	Relevance to assessment	Potential consequence / duty	Framework control
IT Act 2000, s.43	Unauthorized access, copying/extraction, introducing contaminants, disruption or denial of access may attract civil liability/compensation where statutory conditions are met.	Compensation to affected person; exact application depends on facts and current law.	Written authority, strict scope, safe methods, change window, evidence log.
IT Act 2000, s.66	Computer-related acts under s.43 become criminal when done dishonestly or fraudulently.	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both (subject to statutory text and facts).	Intent and authorization review; tester identity and activity logs; stop-work rule.
IT Act 2000, s.66C / s.66D	Identity theft and cheating by personation using computer resources.	Each carries imprisonment up to 3 years and fine up to ₹1 lakh under the Act.	No impersonation of real users outside approved simulations; use test accounts.
IT Act 2000, s.66E	Capturing, publishing or transmitting images of private areas in privacy-violating circumstances.	Up to 3 years' imprisonment or fine up to ₹2 lakh, or both.	No collection of intimate/private imagery; immediate stop and escalation.
IT Act 2000, s.72 / s.72A	Breach of confidentiality/privacy by persons with access, and disclosure in breach of lawful contract, respectively.	Potential criminal consequences under the respective provisions; apply only where their elements are met.	NDA, least privilege, data minimisation, restricted reports and secure deletion.
IT Act 2000, s.70B	CERT-In's statutory role and directions for cyber-incident response.	Applicable directions may impose incident-reporting and log-retention requirements on covered entities.	Incident escalation matrix; preserve logs; check current CERT-In directions.
DPDP Act 2023	Digital personal data processing obligations apply according to the Act's commencement schedule and applicable rules.	Obligations and penalties depend on the provisions in force at the relevant date.	Privacy review, purpose limitation, data minimisation, processor terms and breach workflow.

Important commencement note: the Gazette notification dated 13 November 2025 phases commencement of the DPDP Act. Several institutional/administrative provisions commenced on publication; specified provisions

commence one year later and the main processing obligations in sections 3–17 are scheduled 18 months after publication. As this assignment is dated November 2026, the university must verify the exact commencement status and any rules/notifications effective on the engagement date rather than assuming every provision is already operative.

4.2 International comparison – US CFAA

CFAA provision	Summary	Framework implication
18 U.S.C. §1030(a)(2)	Intentional unauthorized access or exceeding authorized access to obtain information from a protected computer.	Do not rely on a university approval to authorize access to a third-party or US-hosted system without that provider's permission.
§1030(a)(5)	Certain unauthorized conduct causing damage to a protected computer.	Prohibit destructive testing and uncontrolled availability-impacting tests.
§1030(a)(4)	Unauthorized access with intent to defraud and obtaining something of value.	No use of discovered access for personal gain or unrelated activity.
§1030(c)	Sets criminal penalties; maximums vary by offence, harm, aggravating factors and prior convictions.	Do not quote one universal penalty; legal counsel must assess the applicable subsection.

4.3 Personal-data decision

When a test touches systems holding personal data, the engagement requires a privacy impact review before approval. The preferred method is synthetic or masked test data. If production data exposure is unavoidable to confirm a finding, the tester must stop at the minimum proof, avoid bulk extraction, redact identifiers, encrypt evidence, restrict access and notify the privacy lead. The university must identify whether it acts as a Data Fiduciary or processor, review processor/vendor contracts, determine the DPDP provisions in force on the test date, and apply any other relevant sectoral or contractual requirements. The IT Act and applicable CERT-In directions remain relevant independently.

Conclusion: authorization is necessary but not a blanket exemption from law. It must come from the entity that controls the system, cover the exact conduct and respect privacy, contracts and third-party rights. This is an educational mapping, not legal advice; university counsel should approve each engagement.

4.4 Legal references

- India Code – Information Technology Act, 2000: https://www.indiacode.nic.in/bitstream/123456789/13116/1/it_act_2000_updated.pdf
- India Code – Digital Personal Data Protection Act, 2023: https://www.indiacode.nic.in/bitstream/123456789/22037/2/a2023-22.pdf
- MeitY Gazette commencement notification, 13 November 2025: https://www.meity.gov.in/static/uploads/2025/11/c56ceae6c383460ca69577428d36828b.pdf
- US Code, 18 U.S.C. §1030: https://uscode.house.gov/us/usc/119-124/t18/s1030/

TASK 5 – Scope and Rules of Engagement

5.1 Engagement scope template

Field	Required content / example
Engagement ID	UASAP-YYYY-NNN (unique, immutable identifier).
Purpose	Assess security before the university system upgrade.
In-scope assets	Only asset IDs listed in signed Appendix A: portal, LMS, email and specified campus network segments.
Out-of-scope	Third-party SaaS infrastructure without provider consent; personal devices; unrelated public IPs; production student records; safety-critical facilities unless separately approved.
Authorized identities	Named internal/external testers, source IPs, test accounts and supervising lead.
Window	Approved date/time in IST; blackout periods and maintenance freeze periods stated.

Permitted methods	Passive review, configuration review, safe discovery, authenticated checks and low-impact validation explicitly approved.
Prohibited methods	Denial-of-service, destructive payloads, persistence, malware deployment, credential harvesting, bulk data extraction, social engineering or physical access unless separately authorized.
Safety limits	Rate limits, test account limits, data handling, service thresholds and stop conditions.
Contacts	Engagement lead, system owner, SOC/IT operations, privacy officer and emergency contact.
Evidence	Timestamp, asset ID, tool/version, action, result, redaction and secure storage location.
Closure	Revoke test accounts, remove temporary access, return/delete data, retest and sign closure.

5.2 Authorization verification rules

12. Verify the approver's role against the university's delegation-of-authority register.
13. Confirm the approver controls the asset or has written delegation from the owner.
14. Match engagement ID, asset IDs, testers, methods, dates and test window across the approval and RoE.
15. For vendor-hosted systems, attach the provider's written permission and applicable contract approval.
16. Store the signed version in the engagement register; record version, timestamp and approver.
17. Reject expired, unsigned, ambiguous or altered approvals. Any scope change requires a new signed amendment.

5.3 Escalation and stop conditions

- Stop immediately if availability degrades, unexpected personal data appears, a third-party asset is reached, or an unapproved technique is needed.
- Notify the engagement lead immediately; the lead informs the system owner and incident response team.
- Resume only after the issue is assessed and a written change or restart approval is recorded.

5.4 Derived pre-engagement checklist

Check	Yes/No/NA	Evidence / reference
Request and business purpose registered	_____	_____
Asset owner and delegated approver verified	_____	_____
Signed authorization valid and in date	_____	_____
Scope, exclusions and asset IDs confirmed	_____	_____
RoE methods, windows, rate limits and stop rules accepted	_____	_____
Legal, privacy and third-party permissions completed	_____	_____
Named testers, test accounts and source IPs recorded	_____	_____
Emergency contacts and communication channel tested	_____	_____
Evidence storage and retention approved	_____	_____
Lab or staging validation completed where applicable	_____	_____

TASK 6 – Authorization and Disclosure Layer

6.1 Authorization workflow

Step	Responsible role	Required action / record
1. Request	Requesting department	Submit purpose, business owner, asset IDs, desired dates and impact.
2. Triage	Security programme coordinator	Assign engagement ID; check asset ownership, risk

		and assessor eligibility.
3. Review	System owner + privacy/legal + vendor as needed	Confirm authority, data sensitivity, contracts and operational constraints.
4. Approval	Delegated university authority	Sign authorization and approve RoE version.
5. Registration	Programme coordinator	Store signed documents, named testers, timestamps and status.
6. Start gate	Engagement lead	Verify checklist and announce start to operations contacts.
7. Change / stop	Engagement lead + owner	Log change request, pause if required, obtain reapproval.
8. Closure	System owner + security lead	Confirm findings, access revocation, evidence disposition and closure sign-off.

6.2 Coordinated responsible disclosure process

18. Receive the finding through the designated private channel; issue a case ID and acknowledge within 2 business days.
19. Validate safely and request only the minimum evidence needed; do not ask the reporter to continue unauthorized testing.
20. Classify severity and impact; assign a system owner and remediation lead.
21. Default remediation targets: Critical – mitigation plan within 24 hours and fix/mitigation target 7 calendar days; High – 15 days; Medium – 30 days; Low – 60 days. These are programme targets, not statutory deadlines.
22. If the target cannot be met, record compensating controls, a revised date and approval by the security risk owner.
23. Retest the fix within the approved scope; close only after evidence supports remediation or a formally accepted risk.
24. Public disclosure is considered only after remediation or an agreed disclosure date, legal/privacy review and risk assessment.

6.3 Disclosure approach comparison

Approach	Strength	Risk / limitation	University decision
Coordinated disclosure	Allows the owner time to fix and coordinate communication.	Can be delayed if there is no escalation or deadline.	Default approach; use deadlines and escalation.
Full disclosure	Can alert users and create public pressure for remediation.	May expose users or enable exploitation before a fix.	Exceptional only when public interest outweighs harm and legal review approves.
Bug bounty	Provides structured intake and incentives for external researchers.	Needs triage capacity, eligibility rules, safe-harbour boundaries and budget.	Optional later phase; publish explicit scope and rules first.

6.4 Disclosure log fields and decision rules

- Fields: case ID, engagement ID, reporter, asset ID, date received, severity, evidence location, data sensitivity, owner, acknowledgement date, target date, status, retest result and disclosure decision.
- Choose coordinated disclosure by default for all university findings.
- Consider public/full disclosure only if remediation is unreasonably delayed, users face material ongoing risk, the evidence is verified, and legal/privacy leadership approves a safe publication plan.
- A bug-bounty route is used only for assets explicitly listed in a published programme; it never authorizes testing of excluded systems.

Interaction: authorization defines who may test; the RoE defines what they may do; legal/privacy review defines constraints; the finding report feeds the disclosure log; the disclosure decision cannot expand the original testing authority.

TASK 7 – Isolated Ethical-Hacking Lab

7.1 Proposed lab architecture

Component	Example configuration	Role
Host machine	Windows/Linux workstation with VirtualBox; host firewall enabled.	Runs virtual machines and stores controlled lab evidence.
Kali Linux VM	192.168.56.10/24; host-only adapter only.	Authorized assessment workstation.
Target VM 1	192.168.56.20/24; intentionally vulnerable training target.	Receives controlled practice tests.
Target VM 2 (optional)	192.168.56.30/24; test web application.	Provides a second authorized target.
Virtual network	Host-only network 192.168.56.0/24; no bridged adapter; no default route.	Contains traffic between host and lab VMs.
Evidence folder	Encrypted, access-controlled folder on host.	Stores configuration screenshots, logs and reports.

Connectivity model: Kali (192.168.56.10) ↔ Host-only switch/network ↔ Target VM (192.168.56.20). The lab network is separate from the campus LAN and the public internet. Disable shared folders, clipboard and drag-and-drop unless specifically needed and approved.

7.2 Configuration recording and verification operations

25. Create a host-only network in VirtualBox and assign the 192.168.56.0/24 subnet. Record the network name and DHCP setting.
26. Attach the Kali and target VMs only to that host-only adapter. Confirm that no bridged adapter is enabled.
27. Assign unique static addresses: Kali 192.168.56.10/24 and target 192.168.56.20/24. Record VM names, snapshots and operating-system versions.
28. From Kali, verify local interface configuration and test reachability to the authorized target using a basic ping. Record timestamp and output.
29. Confirm the target cannot reach external networks and that the host-only network has no route to the campus network. If isolation cannot be verified, shut down the VMs and correct the configuration.
30. Take clean snapshots before exercises; restore snapshots after testing and securely retain only approved logs.

7.3 Host-only versus NAT

Feature	Host-only	NAT
VM-to-VM communication	Yes, within the host-only segment.	Usually possible through the virtual NAT network, depending on configuration.
Internet access	No by default.	Outbound internet access is normally available.
Isolation	Strong containment from external networks when configured correctly.	Less isolated because guests can initiate outbound connections.
Best use	Controlled security exercises and repeatable lab validation.	Software updates or exercises that require internet access.
Decision	Selected for this assignment because containment is the priority.	Not selected as the default testing network.

The lab keeps testing authorized because only named target VMs are included in the lab inventory, the RoE names the lab subnet and methods, and connectivity is verified before each exercise. A host-only network reduces accidental contact with production systems; it does not itself grant legal permission.

TASK 8 – Reusable Document Library

8.1 Document templates

Document	Purpose	Core fields
D1 – Authorization Form	Proves permission and authority.	Engagement ID; requester; owner; approver; assets; testers; dates; methods; exclusions; signatures;

		version.
D2 – Scope and RoE	Defines boundaries and safe operating rules.	Objectives; in/out scope; IPs/URLs; test accounts; windows; allowed/prohibited methods; rate limits; contacts; stop conditions.
D3 – Finding Report	Records evidence and drives remediation.	Finding ID; asset ID; title; severity; description; impact; reproducibility; redacted evidence; recommendation; owner; due date; status.
D4 – Disclosure and Closure Log	Tracks communications and completion.	Case ID; reporter; acknowledgement; severity; timeline; remediation; retest; disclosure decision; closure approval.

8.2 Structured finding output

The finding report produces a structured record that can be imported into the vulnerability register and disclosure tracker. Example JSON-like record:

```
{
 "engagement_id": "UASAP-2026-001",
 "finding_id": "F-001",
 "asset_id": "LMS-STG-01",
 "title": "Access-control weakness",
 "severity": "High",
 "evidence_ref": "vault://UASAP-2026-001/F-001",
 "data_exposed": "No personal data retained",
 "owner": "LMS System Owner",
 "target_date": "2026-11-19",
 "status": "Open"
}
```

8.3 Input validation test entries

Test	Input	Expected result
Valid	Signed form; known asset ID; approver in authority register; dates valid.	Accept and register engagement.
Boundary	One asset added by approved scope amendment; test window ends at 23:59.	Accept only after signed amendment; reject activity after end time.
Invalid	Missing signature or unknown asset ID.	Reject; no engagement start.
Invalid	Third-party SaaS target without provider consent.	Reject or hold pending provider approval.
Invalid	Finding report includes unredacted student names or passwords.	Quarantine report, restrict access and request redaction; follow incident procedure if exposed.

Integration: D1 authorizes the work; D2 defines its limits; D3 creates a finding record; D4 tracks coordinated disclosure and closure. All documents use the same engagement ID to preserve traceability.

TASK 9 – Integration, Testing and Refinement

9.1 End-to-end walkthrough

Phase	Walkthrough action	Evidence / decision
Request	IT department requests assessment of LMS staging before upgrade.	Request UASAP-2026-001 registered.
Authorization	LMS owner confirms ownership; management signs; privacy lead reviews test data; vendor consent attached if hosted.	Signed D1 and approval record.
Scope	RoE lists LMS-STG-01, test accounts, two-day window and low-impact methods; production LMS excluded.	Approved D2 version 1.0.
Lab rehearsal	Kali 192.168.56.10 and target 192.168.56.20 on host-only network; configuration and reachability recorded.	Lab checklist and test log.
Assessment	Tester performs only approved checks; notices access-control weakness using test accounts.	Timestamped evidence; no real student records copied.
Finding	D3 records High severity, impact, redacted	F-001 entered in vulnerability register.

	evidence and recommendation.	
Disclosure	System owner acknowledges; remediation plan due within 15 days under the programme's illustrative High target.	D4 case log updated.
Retest and closure	Tester verifies fix under same approved scope; access is revoked and evidence retained per policy.	Retest passed; closure signed.

9.2 Systematic test cases

Test ID	Condition	Expected framework response	Result
T01	Authorization missing	Block start; request signature; log rejection.	Pass – gate prevents start.
T02	Out-of-scope asset requested	Stop; do not scan; require scope amendment and owner approval.	Pass – boundary enforced.
T03	Legal/privacy conflict discovered	Pause; refer to legal/privacy; redesign using synthetic data or cancel.	Pass – review gate engaged.
T04	Disclosure deadline missed	Escalate to security head and risk owner; document compensating controls and revised date.	Pass – escalation path defined.
T05	Service degradation during test	Stop immediately; notify operations; preserve logs; resume only after approval.	Pass – stop condition enforced.

9.3 Walkthrough issues and refinements

Issue observed in design walkthrough	Refinement made
A verbal approval could be mistaken for permission.	Require a signed authorization record and authority-register check.
A target hostname could resolve to a vendor-owned IP.	Require ownership verification and third-party written consent.
Evidence could contain personal data unnecessarily.	Require minimum proof, redaction, encryption and privacy escalation.
Disclosure could remain open without an accountable owner.	Assign one remediation owner, severity-based target and escalation date.
A tester could continue after the window expires.	Add automated calendar reminders and a hard stop in the engagement checklist.

The integrated design is reproducible because the engagement ID links the request, approval, RoE, lab log, finding, disclosure case and closure record.

TASK 10 – Scalability and Governance Evaluation

The following is a planning simulation to test whether the governance model scales. These are illustrative estimates, not observed university performance data. The baseline reflects the assignment scenario of approximately 20 systems and 50 staff.

Measure	Department pilot	Initial programme	University-wide / third-party
Systems assessed	5	20	100 (planning scenario)
Testers	3	8	25
System owners / contacts	2	8	30
Approval turnaround target	2 business days	4 business days	7 business days
Scope validation steps	5	7	9
Finding review target	1 business day	2 business days	2 business days
Governance model	Single coordinator	Central coordinator + domain owners	Central policy + delegated domain approvers + vendor gate

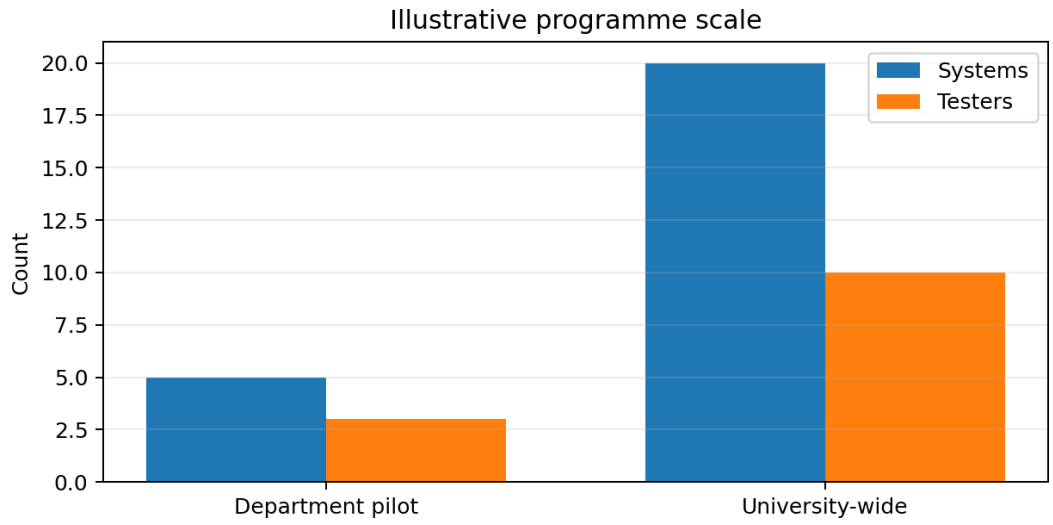


Figure 1. Illustrative scale comparison for the department pilot and initial programme.

10.1 Process experiments and interpretation

Process	Pilot estimate	University-wide estimate	Interpretation / refinement
Approval	2 days; 5 steps	7 days; 9 steps	Use delegated approval for low-risk, owned assets; retain legal/privacy escalation for sensitive systems.
Scope validation	1 owner; 5 checks	Multiple owners; 9 checks	Use a central asset register and standard asset IDs; automate ownership and expiry checks.
Finding triage	1 day; 1 reviewer	2 days; 2 reviewers	Use severity-based routing and a shared vulnerability register; critical findings trigger immediate escalation.

10.2 Governance refinement based on evaluation

- Introduce risk tiers: low-risk staging assessments use a standard approval path; sensitive or high-impact systems require additional legal/privacy and executive review.
- Create a central engagement register with mandatory fields, expiry reminders and status dashboards.
- Pre-approve standard safe test methods, but require a signed engagement-specific RoE for every target and time window.
- Require external assessors to complete onboarding, confidentiality commitments, identity verification and least-privilege access.

The simulation indicates that adding systems and assessors increases coordination effort. Standard templates and delegated approval reduce repetitive work, while sensitive-data and third-party gates remain mandatory.

TASK 11 – Defence Under a Changed Requirement

Changed requirement: the university moves to continuous and third-party assessments, applies stricter data-protection rules and requires a shorter disclosure timeline.

11.1 Component disposition

Component	Decision	Reason / change
Authorization workflow	Modify	Use standing programme-level authorization for defined recurring activities, but retain asset-specific scope, time limits and named assessor approval.
Scope and RoE	Retain + modify	Add continuous-testing windows, rate limits, automated stop conditions and per-vendor

		boundaries.
Legal/privacy mapping	Redesign	Add a mandatory data-protection review for every new data flow, processor and cross-border service.
Threat model	Retain	Refresh quarterly and after major incidents or architecture changes.
Ethics module	Retain + strengthen	Add third-party training, sanctions, conflict-of-interest declaration and incident notification obligations.
Isolated lab	Retain + expand	Add representative staging environments and synthetic datasets for recurring validation.
Document library	Modify	Version-controlled templates, digital signatures, machine-readable asset/finding records and audit history.
Disclosure	Redesign	Shorter targets: Critical acknowledge within 4 hours and mitigation plan within 24 hours; High acknowledge within 1 business day and plan within 3 business days; Medium/Low triaged within 3 business days.
Governance evaluation	Retain + automate	Continuous metrics for approval latency, scope drift, overdue findings and third-party compliance.

11.2 New component – Continuous Assessment Control Plane

A Continuous Assessment Control Plane (CACP) is added to manage recurring scans and external assessors without removing engagement-level accountability.

CACP control	Operation	Integration
Asset allowlist	Only registered asset IDs and approved endpoints can be assessed.	Consumes asset register and RoE.
Time-bound authorization	Each recurring job has an owner, approval reference, expiry date and permitted schedule.	Consumes signed authorization and scope version.
Assessor identity	External assessors use named accounts, MFA, short-lived credentials and least privilege.	Connects onboarding records to authorization.
Policy enforcement	Approved rate limits, prohibited methods and stop conditions are configured before jobs run.	Enforces ethics and RoE.
Data protection	Synthetic data by default; redaction and encryption for evidence; defined retention and deletion.	Implements privacy/legal controls.
Finding automation	Structured findings create tickets with severity, owner, SLA and disclosure status.	Feeds D3 and D4 registers.
Audit and pause	Every run is logged; owner or security lead can pause a job immediately.	Supports incident response and closure.

11.3 Evidence-based defence

- Walkthrough evidence: the end-to-end path links request, signed authority, scope, lab validation, finding and closure; this supports traceability.
- Test evidence: missing authorization, out-of-scope assets, privacy conflicts and delayed disclosure each have explicit fail-safe responses.
- Scalability evidence: the illustrative evaluation identifies approval and ownership bottlenecks and supports delegated low-risk approvals plus a central register.
- Legal evidence: the mapping separates Indian primary law from the US comparison and makes privacy/third-party review a precondition.
- Disclosure evidence: severity-based deadlines, named owners and escalation make the shorter timeline measurable.

11.4 Remaining trade-offs and future improvements

Trade-off / limitation	Impact	Future improvement
Continuous monitoring increases alert volume.	Security teams may face triage fatigue and false positives.	Tune detection rules, use risk-based prioritisation and review false-positive rates.

Automation can block legitimate testing or miss unusual scope changes.	Overly strict controls may slow urgent work; weak controls may allow scope drift.	Use human approval for exceptions, test policy rules regularly and maintain emergency stop controls.
Third-party hosting limits direct control.	The university may depend on vendor cooperation and contractual permissions.	Add standard security-assessment clauses, audit rights, notification duties and evidence-handling terms.
Shorter disclosure targets require rapid remediation capacity.	Teams may not always deliver permanent fixes within the target.	Use temporary mitigations, documented risk acceptance and executive escalation.

Conclusion

The proposed framework provides a practical governance lifecycle for authorized university security assessments. It distinguishes authorization from legality and ethical appropriateness, establishes repeatable scope and conduct controls, protects personal data, contains hands-on exercises in an isolated lab and ensures that findings move through coordinated disclosure to verified closure. Its modular documents and risk-tiered approvals support growth from a small departmental pilot to a university-wide programme with external assessors. Continuous assessment should be introduced only with stronger asset allowlists, time-bound authorization, privacy controls, audit logging and immediate pause capability.

References

- Government of India. Information Technology Act, 2000 (as amended). India Code. https://www.indiacode.nic.in/bitstream/123456789/13116/1/it_act_2000_updated.pdf
- Government of India. Digital Personal Data Protection Act, 2023. India Code. https://www.indiacode.nic.in/bitstream/123456789/22037/2/a2023-22.pdf
- Ministry of Electronics and Information Technology. Gazette notification G.S.R. 843(E), 13 November 2025 – phased commencement of the DPDP Act. https://www.meity.gov.in/static/uploads/2025/11/c56ceae6c383460ca69577428d36828b.pdf
- United States Code. Title 18, §1030 – Fraud and related activity in connection with computers. https://uscode.house.gov/us/usc/119-124/t18/s1030/
- Assignment brief: ITA1439, CO1 – Assignment 1, pages 1–8 (provided PDF).